QUORIVIO

Administrator guide

Version 0.1.0-dev · Build dev-20261024 · 22 October 2026



Alessandro De Salvo · github.com/desalvo/quorivio

Documented features match the development build; unverified and planned operations are explicitly marked.

Contents

Architecture and responsibility 4

Installation 5

CI/CD and releases 6

Operations and GDPR 7

Technical appendices 8

Integrated slide administration 9

Approvals and platform configuration 10

Full backup and upload limits 11

Real 500-user response and connected-presence test 12

Opt-in account Gravatar and privacy 13

First-installation checklist 14

PostgreSQL and recoverability 15

Repeatable Kubernetes deployment 16

Security and GDPR operating controls 17

CI/CD and operational troubleshooting 18

Q&A; and word cloud operations 19

Streaming uploads and checks 20

SMTPS and account security 21

Attachment antivirus scanning 22

Email MFA confirmation and atomic settings 23

GitHub and Facebook OAuth deployment 24

New session operations and verification 25

Widgets, satisfaction scores and page composition 26

Profiles, collaboration and multiple ratings 27

Visual editing, formatting and comments 28

PDF/PPTX import from the workspace 29

Drag-and-drop page sequence 29

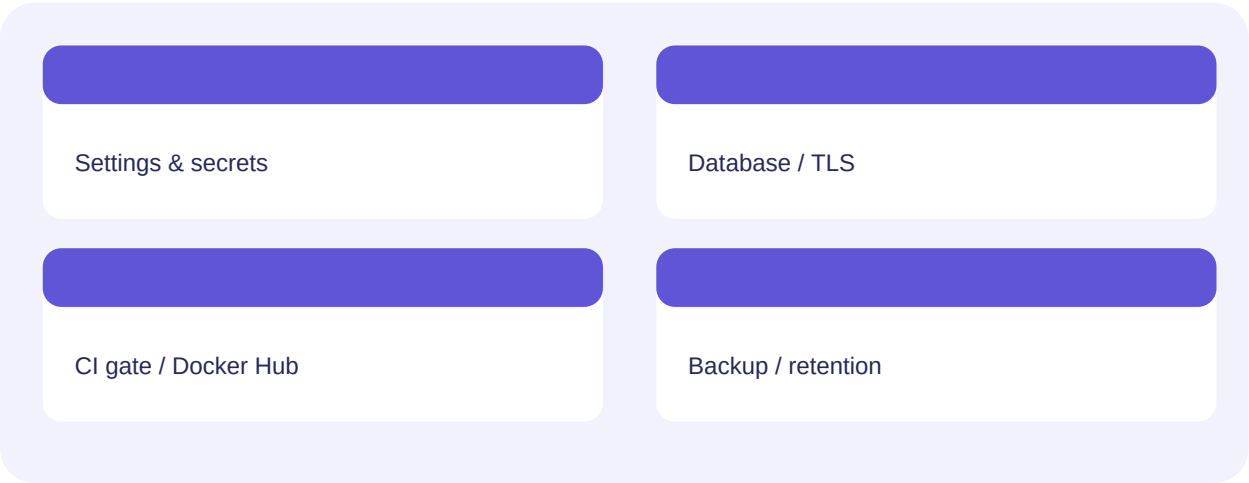
Widget positioning canvas 30

Federated OIDC sign-in (experimental) 31

Cross-replica notifications and shared storage 32

Appendices and known limitations 33

Architecture and responsibility



System components

React/Vite frontend; Node/Express backend; PostgreSQL as authoritative data store; WebSockets for live updates; Kubernetes Kustomize generator and Compose. Multi-replica coordination is not validated.

Release boundaries

This is a development build (0.1.0-dev). User-confirmed green CI applies to the preceding package, not untested changes. No AgID or GDPR certification is claimed.

Installation

Repository and secrets

Source: github.com/desalvo/quorivio. Configure PUBLIC_BASE_URL, DATABASE_URL and other secrets outside source control. Use HTTPS, least privilege and tested backups.

Container deployment

Review compose.yaml and .env.compose.example; populate credentials before startup. Rootless Podman has not undergone complete runtime verification.

Kubernetes wizard

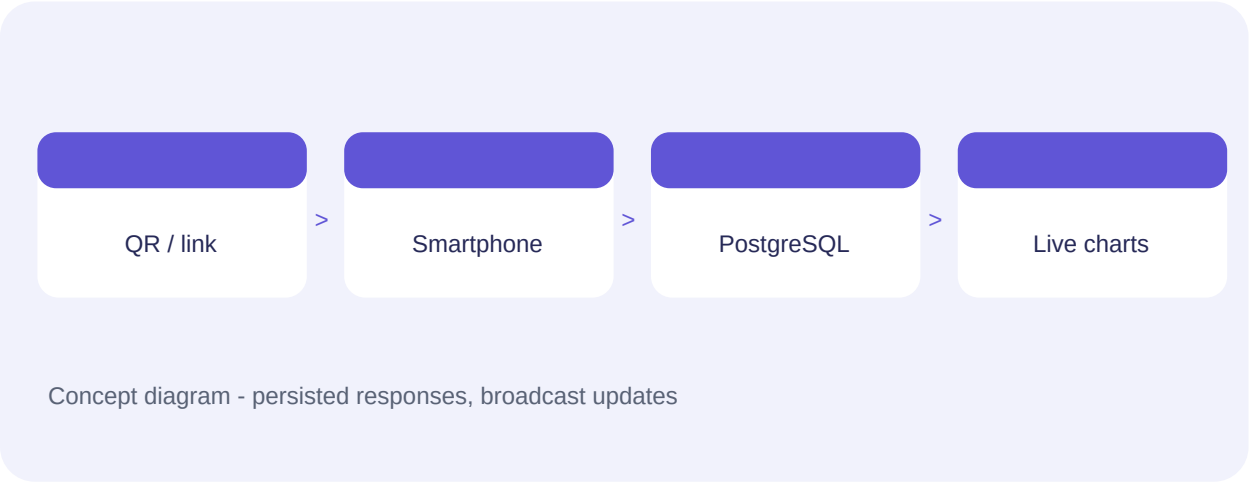
Run python3 tools/k8s_wizard.py --unattended --output ./k8s-generated --set host=quorivio.example.org. This writes segmented Kustomize manifests and persists only non-default settings; it does not generate passwords.

Ingress controllers

Select NGINX, HAProxy community or HAProxy Technologies with the proper ingressClassName. Older HAProxy implementations may require controller-specific legacy annotations.

PostgreSQL

Choose an internal PostgreSQL StatefulSet/PVC or external database. External mode requires a supplied DATABASE_URL Secret and verified TLS. Major upgrades from PostgreSQL 17 to 18 require a planned migration and backup, not an image swap.



Concept diagram - persisted responses, broadcast updates

CI/CD and releases

Actions gate

GitHub Actions runs quality checks, container build and blocking Trivy HIGH/CRITICAL scanning prior to publication. Configure required branch checks and rulesets.

Docker Hub

Within environment production set DOCKERHUB_USERNAME=desalvo and secret DOCKERHUB_TOKEN. Push to main yields latest; a release tag v* yields the matching tag. Never store tokens in git.

Versioning

Version remains 0.1.0-dev. Commit/push/tag/release are operator actions; GitHub may publish automatically only after an authorized repository event and passing gate.

Operations and GDPR

Monitoring

Inspect liveness/readiness, application logs, database capacity and TLS. Test restores, not only backups. Restrict runtime to a single application replica until multi-instance WebSockets work reliably.

Data protection

Configure privacy notices, controller/processor roles, processing legal bases and retention. Define data-subject request and breach procedures. Technical checks do not replace organizational and legal assessments.

Security

Use external Secret management, dependency/container scans and SBOM records. Perform tenancy isolation testing and penetration testing before production use.

Technical appendices

Disaster recovery

Specify RPO/RTO, rehearse restore into a separate environment, verify application data consistency and session availability before sign-off.

Troubleshooting

Readiness 503: check PostgreSQL TLS/URL and availability. Docker Hub auth failure: inspect production secrets. Ingress issues: check controller, DNS and TLS. Missing live results: inspect WebSocket connections.

Integrated slide administration

Conversion dependencies

The offline converter uses Poppler and LibreOffice for PPTX. Execute it in an isolated environment, especially for untrusted documents.

Database and storage

The additive schema creates a slide activity type and presentation_slide_assets references. Rehearse migrations and backups before production. Media remain in private persistent storage.

Audience isolation

Only the image belonging to the current slide in an active session is served to participants; other attachments remain private. Integrated security testing remains pending.

Approvals and platform configuration

Approving presenters

Open Administration and load accounts and settings. Create an account with a temporary 12+ character password, or select role and approval for an existing account, then save. Unapproved presenters cannot create sessions; test the flow end-to-end before deployment.

Public address and retention

Set an absolute HTTPS address to use in session QR codes and URLs. Set the global closed-session retention in days (default 60). Updating the URL does not retroactively update downloaded QR codes.

Initial credentials

Demo password 000000 may be used only with explicit non-production opt-in and must be changed at first login. Use strong initial credentials in production. New accounts remain pending admin approval.

Not yet implemented

SMTP/SMTPS settings and test message, email/TOTP MFA, SSO providers, XLSX exports and uploaded-file management are still planned, not available.

Full backup and upload limits

Backup and restore

Full database and attachment backups are not available in the UI. Use trusted PostgreSQL backup procedures, consistent media backups and isolated recovery tests; never import untrusted database dumps.

Upload maximum

The initial limit is 100 MB. The admin API supports max_upload_mb; the Kubernetes wizard accepts --set max_upload_mb=100 and renders NGINX and HAProxy Technologies ingress annotations. Settings changes cannot automatically change a running ingress.

Outstanding work

Actual uploads, malware scanning, quotas, complete automated restoration and related UI remain pending.

Real 500-user response and connected-presence test

Per-account official demo

Every account has a private Quorivio · Prova tecnica 500 partecipanti presentation, automatically recreated empty if deleted. It remains unpublished until the owner starts it. Its pages include a live connected-participant counter, primary and optional secondary questions, 0–9 ratings, reactions and question results.

Starting and observing

Sign in as owner, open the test presentation, select Start, publish the second page and open Presenter screen. Keep Connected participants visible. The count reflects open WebSockets, not successful HTTP votes alone.

Authentication and CLI

Install aiohttp and use the version-controlled tools/live_500_answers.py from GitHub. Set QUORIVIO_LOAD_PRESENTER_COOKIE to the presenter q_auth cookie in the shell environment. Never paste the cookie into command arguments or stored reports. Require an authorized HTTPS host and exact --confirm-host.

Suggested run

Run python3 tools/live_500_answers.py --base-url https://quorivio.example.org --confirm-host quorivio.example.org --confirm-run --open-test-question --live-presence --users 500 --concurrency 30 --ramp-seconds 900 --hold-seconds 90 --json-out ./load-results.json. The CLI holds independent WebSockets and validates both 500 server-confirmed answers and the presenter-visible peak.

Reset and repeat

Choose Reset to ready in an active or paused test session and confirm. The operation erases responses and participant identities, retains authored pages, and rotates the join QR. For a CLI-managed rerun supply --reset-before together with --open-test-question; old QR links and visitor cookies become invalid.

Safe interpretation

Review JSON totals, live participant count, response time p50/p95/p99, error counters, and infrastructure telemetry. Run only against infrastructure you administer, with permission, TLS, isolated synthetic data, monitoring, backups and a bounded test window. Use tools/load_500.py separately for the standalone simultaneous-WebSocket scenario.

Opt-in account Gravatar and privacy

User-specific preference

Every approved user may choose Use Gravatar for my account photo in Profile. The integration is disabled by default and cannot be enabled silently by a presenter or administrator on another account.

Create or import

Follow the Add or update photo on Gravatar link to upload on the external Gravatar website. Return to Quorivio and select Import / refresh Gravatar. Existing avatars attached to the registered account email are imported into local Quorivio storage.

Login synchronization

On successful login the server checks the fixed HTTPS Gravatar avatar endpoint, compares the content SHA-256 and imports changed photos. Browser clients receive only private Quorivio photo URLs.
Third-party outages never block login. Uploading a local profile photo disables automatic Gravatar refresh.

Privacy and retention

Opting in exposes a SHA-256 identifier derived from the account email to Gravatar. Update privacy information and obtain an appropriate legal basis. Use shared protected storage, antivirus scanning and durable old-photo erasure. Uncheck the preference in Profile to disable further synchronization.

First-installation checklist

Before exposing the instance

Prepare public DNS and valid TLS, strong secrets, PostgreSQL, persistent storage, least-privilege admin access and tested backups. The known demo password 000000 is restricted to explicitly opted-in nonproduction installations.

External URL

Set the real HTTPS public address in Administration. Session invitations use it. When it changes, ask presenters to regenerate previously downloaded QR codes and replace old slide assets.

Approval workflow

Registration is not approval. Check identity and role need before approving a user or presenter; remove unnecessary access promptly and document approvals.

Availability checks

Check /api/health/live, /api/health/ready, database health, and TLS. Reproduce an actual presenter-and-participant workflow. Green CI reported for an earlier revision does not validate every later change.

PostgreSQL and recoverability

Internal deployment

The wizard can generate a PostgreSQL 18.6 StatefulSet and PVC. Plan durable storage, backups, version upgrades and operational monitoring; a single StatefulSet does not provide database high availability.

External database

Choose postgres_mode=external and configure host, port, TLS verify-full and Secret references. Validate server identity and CA trust. Never commit DATABASE_URL credentials.

Schema migrations

Test migrations on a realistic database snapshot before production. Moving from PostgreSQL 17 to 18 requires a supported major upgrade; changing the container tag alone is insufficient.

Backup and restore

Full admin UI export/import is pending. Use supported PostgreSQL tools and consistent backups of external assets, then perform isolated restore drills and document RPO, RTO, encryption and ownership.

Repeatable Kubernetes deployment

Generate manifests

Run python3 tools/k8s_wizard.py --unattended --output ./k8s-generated --set host=quorivio.example.org --set max_upload_mb=100. Review saved custom overrides and ensure credentials never enter the generated configuration.

Ingress controllers

Choose NGINX or the actually deployed HAProxy variant. Ingress class and legacy annotation conventions differ. Confirm that upload body-size restrictions align with backend application limits.

Apply safely

Review kubectl kustomize output and run kubectl apply -k only after validation. Verify namespace, TLS, Secrets, volumes, resource limits and readiness checks. Cross-replica WebSocket operation is not validated.

Changing configuration

Regenerate and diff manifests after public URL, Ingress class or upload size changes. The admin settings UI cannot directly patch a live Kubernetes Ingress; document a rollback procedure.

Security and GDPR operating controls

Privacy governance

Assign controller and processor roles; record legal basis, notices, recipients, subprocessors and retention periods. Current technical controls are partial and cannot themselves establish GDPR compliance.

Retention

The initial global period for closed sessions is 60 days. Verify applicable retention duties, backup policy and deletion jobs before changing it. Audit evidence and backup retention may be separate.

Cookies and account approval

Anonymous access uses a functional cookie and chosen pseudonym. Necessary cookies are not the same as optional tracking consent. Registered accounts require approval; SSO and MFA are available in the application; SMTP/SMTPS is configurable in server settings. External providers require real-world verification.

Logs and incidents

Limit access to audit logs and exclude passwords, tokens and unnecessary response content. Document incident escalation, credential rotation, access revocation and breach reporting rules where applicable.

CI/CD and operational troubleshooting

Publication flow

GitHub Actions runs quality, container build and blocking Trivy HIGH/CRITICAL security gates before production publication to desalvo/quorivio. Protect main and the production environment.

npm errors

Use a committed reproducible lockfile with npm ci when available. A previous workflow disabled caching because package-lock.json was absent; avoid weakening quality gates.

Trivy findings

Inspect the vulnerable runtime path and update or remove the relevant dependency. Build-only npm tooling should not remain in the runtime; do not silently ignore HIGH or CRITICAL vulnerabilities.

Known production blockers

Real provider credentials, SMTP delivery, browser workflows, Kubernetes multi-replica deployment, GDPR evidence and load/security acceptance remain pending.

Q&A and word cloud operations

Persistence

The audience_words, audience_questions and audience_question_votes PostgreSQL tables belong to sessions, with cascading deletion. Apply the schema before starting the upgraded backend.

Authorization

Posting requires a valid participant cookie and an open activity in an active session. Moderation and private analytics require authenticated presenter access.

GDPR and retention

Audience questions and words may contain personal data. Configure appropriate notices, moderation and retention, and test concurrency and abuse controls before production.

Streaming uploads and checks

Uploading files

Uploads are progressively written to private storage; type signature, length and default 100 MB limit are checked. Keep the browser open until confirmation. The Compose/Helm deployment bundles antivirus scanning; shared storage is still pending.

SMTPS and account security

SMTP configuration

Open Server Settings to configure SMTP host, implicit-TLS port, account, password and sender. Credentials are encrypted at rest; the password is never returned to the browser. Send a test message to verify delivery.

Tests and restrictions

SMTPS uses certificate-validated TLS; actual mail delivery still needs acceptance testing; email reset and one-time MFA recovery codes are implemented. STARTTLS is not enabled.

AUTH_SECRET retention

Keep a stable protected AUTH_SECRET. Changing it without migration prevents decryption of stored MFA secrets.

Attachment antivirus scanning

Enable ClamAV

Start the managed Compose/Helm deployment: ClamAV is bundled on the private network with persistent signature updates and QUORIVIO_AV_REQUIRED=true. With mandatory scanning a missing scanner must block the upload, not silently accept it.

Operational checks

In an authorized test environment, test benign files and the EICAR test pattern, examine the logs, and verify rejected assets leave no database record. This feature is not yet validated with a real ClamAV deployment.

Limits

Malware scanning does not replace MIME checks, GDPR processes or isolated document conversion. ClamAV is bundled with Compose/Helm; real-runtime validation remains necessary. See docs/ANTIVIRUS_UPLOADS.en.md.

Email MFA confirmation and atomic settings

Email MFA enrollment

In Security/MFA, enter the current password to request an enrollment code. Email MFA is NOT enabled until the six-digit email code is confirmed within ten minutes. TOTP remains independently configurable.

Limits and disable

Five invalid codes exhaust an enrollment. No more than three enrollments per account per minute may be issued. Confirmation or disabling revokes existing sessions, requiring sign-in again.

Server settings and profile images

Public URL, retention and upload limit changes are validated together and written atomically. Private profile photos use per-user row locking for replace/delete and dispose of superseded files. Multi-replica and browser acceptance are still outstanding.

Operator checks

Test a real SMTP server, expired and incorrect codes, login using each enabled factor, invalid combined settings updates and .quorivio UUID collisions. A PostgreSQL HTTP CI test has been added but has not been run on the new revision yet.

GitHub and Facebook OAuth deployment

Client credentials

Set OAUTH_GITHUB_CLIENT_ID, OAUTH_GITHUB_CLIENT_SECRET, OAUTH_GITHUB_REDIRECT_URI and their OAUTH_FACEBOOK_* counterparts. Register HTTPS callbacks /api/auth/social/<provider>/callback.

Security boundaries

Never link accounts silently by email; local approved-user authentication is required first. OAuth state is stored in PostgreSQL and consumed once across replicas; verify provider redirects and callback host, MFA policy, and shared database operation before production.

New session operations and verification

Import/export safety

Approved presenters can duplicate sessions and transfer definition-only JSON. Administrators must distinguish these exports from the still-unimplemented full-instance backup and restore capability.

Collaboration and audit

Verify that each co-presenter belongs to the same organization and has an approved presenter role. Review response invalidation events. Do not confuse live editing with deletion of historic records.

Release checks

The prior green CI does not validate the newly added screens. Require API/PostgreSQL integration tests, browser verification, cross-tenant isolation tests and dependency scans before production deployment.

Widgets, satisfaction scores and page composition

Manual identity

Application version: 0.1.0-dev. Documentation build: dev-20261024. Git release tags and revision numbers are excluded; they do not require rebuilding manuals if the documented application build is unchanged.

Widget palette

The palette includes a 0–10 satisfaction rating, emoji reactions, text, divider, indicative timer and QR placeholder. Widgets complement rather than replace poll or quiz answers.

Presenter workflow

Open the session, choose Page layout for an activity, select + rating or another widget, edit its label, reorder by drag and drop or keyboard-friendly arrow buttons, then save the layout. Existing answers remain untouched.

Participant workflow

Join with the session QR and pseudonym. Where enabled, choose a number from 0 to 10. One satisfaction response per participant per activity is stored separately from quiz answers and emoji reactions.

Statistics

Use Satisfaction 0–10 in the session view to see an overall count and average and a per-page breakdown. Minimum, maximum and distribution are available through the protected API. Do not disclose participant identities on public screens.

Known limitations

The freeform canvas supports move, resize, rotation and keyboard operations; device-specific touch and visual acceptance remain pending. Timer/QR behavior depends on page context and is not equivalent to an interactive PowerPoint. Real browser/PostgreSQL acceptance remains pending.

Profiles, collaboration and multiple ratings

Project opening

The workspace clearly distinguishes Author / owner and Invited collaborator for each listed session.

Presenter profile

Load the profile in the Presenter profile area, set the public display name and an HTTPS photo URL, then save. Direct PNG, JPEG and WebP upload up to 5 MiB is supported: the previous file is removed. Verify image rights, consent and shared volume persistence.

Profile widget

Open Page layout, add + profile, choose a session presenter, and save. Repeat for multiple profiles; Remove deletes individual widgets.

Independent ratings

Insert multiple rating widgets, selecting Question, Quiz, Session or Presenter as their target. Select the presenter where applicable. A participant can score each widget once.

Statistics and limitations

Presenter statistics include a count and average for each widget. The quiz target currently maps to an activity rather than a multi-question quiz. The PostgreSQL schema migration requires live validation.

Visual editing, formatting and comments

Widget options

In Page layout add multiple widgets. Rating widgets require a title and support an optional description. Expand Style and animations to choose font, size (10–96), color, bold, italic, underline, strikethrough, and fade/slide.

Text editing

Double-click the title input to select and edit the text, then save the page. Drag to reorder or use the accessible up/down controls.

Rating comment

Each rating widget requires a title. Participants may write an optional comment up to 1,000 characters alongside a 0–10 rating. Comments remain private and are not included in public aggregates.

Question widgets

Add a question widget in single, multiple, free-text or file mode. In this build it is an additional visual block, not yet an independent response channel.

Limits

A freeform widget canvas is available experimentally; production browser validation is pending, as is fully integrated per-widget media editing. Browser/PostgreSQL verification remains required.

PDF/PPTX import from the workspace

Prerequisites

Direct conversion is experimental and disabled by default. Python 3 and Poppler are required; LibreOffice is needed for PPTX. Never enable in production without an independently sandboxed conversion worker.

Presenter procedure

1. Open a session you own or co-present. 2. In Attachments select Import PDF/PPTX directly. 3. Select a file up to 100 MiB. 4. Wait for the result. 5. Verify inserted slide pages and open the first one for participants.

Limits

Maximum 200 pages. Slides are flattened to images; animation, video and transitions are not preserved. If QUORIVIO_ENABLE_CONVERTER is unset, the endpoint returns 503. The current subprocess is not a production sandbox.

Troubleshooting

HTTP 503: worker not configured. 415: unsupported file. 413: oversized file. 500: inspect restricted server logs and conversion dependencies. Slide insertion rolls back on failure.

Drag-and-drop page sequence

In the presenter workspace, drag a page row onto another page to change sequence order. Keyboard users can use Up/Down controls instead. Duplicate page creates a new page without historical responses. The operation preserves page IDs, existing answers and the currently open page. Closed sessions cannot be reordered.

Drag-and-drop requires HTML5 support and a connection to the backend; reload the session if an error occurs.

Widget positioning canvas

Using the canvas

Open Page layout. Drag widgets by their bodies, resize from the edges, rotate using the circular handle and double-click to edit titles. The white 16:9 slide has rulers and fullscreen editing.

Removal and persistence

Remove deletes only the selected widget. Choose Save layout to store percent-based positions; saved arrangements reappear when the page is opened.

Keyboard access

The widget list, Up/Down buttons and configuration menus remain available independently from dragging. Advanced spatial keyboard controls require accessibility testing.

Limitations

Real mobile browsers, PostgreSQL migration and layout interactions remain unverified. Topic-question widgets provide independently paginated streams of ten questions per presenter page.

Federated OIDC sign-in (experimental)

Availability

Google, generic OIDC or custom OIDC sign-in is only displayed when the administrator configures all HTTPS provider parameters. GitHub and Facebook offer experimental OAuth2 flows; SAML is not yet integrated.

Link identity

Sign in with your approved local account and choose Link in your profile. Authenticate at the IdP and confirm success. Matching email alone never links an identity.

Federated login

After linking, choose the configured IdP from the sign-in page. Users with local TOTP MFA enabled must continue using their local password and MFA code.

Production limitations

Real IdP tests, PostgreSQL migration checks, multi-replica shared state and security review remain open. See docs/OIDC_SSO.en.md; this flow is not production certified.

Cross-replica notifications and shared storage

Synchronization

PostgreSQL LISTEN/NOTIFY propagates WebSocket updates across instances. Payloads carry IDs only, not personal data.

Storage

Multiple replicas require an actual ReadWriteMany PVC supported by the cluster. Helm can mount an existing claim.

Limitations

HTTP rate limits use shared PostgreSQL windows, but OAuth/OIDC state and provider flows still need multi-replica validation; do not deploy untested replicas. Real cluster/browser validation is pending.

Appendices and known limitations

Status: development. Before operational deployment, review docs/DEVELOPMENT_STATUS.md, docs/GDPR.en.md and docs/SECURITY.md.

Visual diagrams are illustrative reproductions of workflows, not browser screenshots.